

CUA Windows VM – Network & Host Requirements (IT Handoff)

Goal (High level)

A Linux Kubernetes pod runs an automation agent that calls a reverse proxy on a Windows VM over HTTPS:443. The reverse proxy enforces authentication (API key or mTLS) and forwards requests only to http://127.0.0.1:8000, where the CUA Computer Server listens. Port 8000 remains loopback-only (never exposed on the network).

Network / Firewall Rules

Ingress to Windows VM (from K8s)

- Allow: TCP 443 → WIN_VM_IP:443 from K8s pod CIDR(s) only.
- Deny: All other inbound traffic to the VM (do not expose 8000).

Egress from Kubernetes

- Allow: outbound TCP 443 to WIN_VM_IP:443 (VM reverse proxy).
- Allow: outbound TCP 443 to OpenAI (via LiteLLM) for model calls.
- Note: NetworkPolicies are L3/L4. For domain-based control use an egress gateway or service mesh policy.

DNS (recommended)

Create an internal A record, e.g. cua-vm-01.corp.local → WIN_VM_IP.

Windows VM Build Requirements

1) Reverse Proxy (IIS or nginx)

- Bind HTTPS on 0.0.0.0:443 with a valid TLS certificate.
- Enforce auth:
 - Option A – API key: require header X-API-Key: <secret>.
 - Option B – mTLS: require a client certificate signed by internal CA; pod holds client keypair.
- Forward only to http://127.0.0.1:8000 (no other upstreams).

2) CUA Computer Server

- Install locally on the VM (Python package) and bind 127.0.0.1:8000 (loopback).
- Run as a Windows Service (e.g., NSSM) so it starts on boot.
- Windows Firewall: Allow inbound 443 from approved K8s CIDR(s). Block inbound 8000.

3) Interactive Desktop Session

- Automation cannot bypass Windows login. Ensure one logged-in desktop session for the service account:
 - Configure Autologon for a dedicated service account.
 - Disable Ctrl+Alt+Del requirement.
 - Prevent idle lock/screen saver (power & GPO settings).
- These policies apply to the CUA-controlled session (not necessarily global).

Authentication Options (Reverse Proxy)

- API key: Pod sends X-API-Key: <secret>. Proxy rejects 401/403 if missing/invalid.
- mTLS: Proxy requires valid client certificate (signed by internal CA). Optionally keep API key as second factor.
- Secrets: Store keys/certs in Kubernetes Secrets; rotate per policy.
- Transport: TLS 1.2+; prefer modern ciphers; enable access logs.

Security Posture (at a glance)

- Port 8000: loopback-only; never exposed.
- Only HTTPS:443 exposed on the VM and restricted to K8s pod CIDR(s).
- Proxy performs TLS termination and authorization (API key and/or mTLS).
- Agent calls https://cua-vm-01.corp.local; proxy forwards to http://127.0.0.1:8000.
- One active agent per desktop session (no concurrent control of the same GUI).
- Enable proxy access logs and CUA server logs for audit.

Operational Guidance

- Dedicated VM recommended—treat each VM as an “automation container”.
- Scaling: use multiple VMs, or Windows Server with separate RDS user sessions and per-session CUA servers (advanced).
- Monitoring: RDP optional for human observation only; agent does not require RDP/VNC for control.

Architecture Diagram

